PROTEXXA CYBER NATIONS SCOTIARISE CYBER SECURITY ANALYST PROGRAM
ASSIGNMENT 6: PREVENTION & RESPONSE PLAN

PREVENTION & RESPONSE PLAN

EQUIFAX

2017 DATA BREACH RISK ASSESSMENT ANALYSIS



LEAD RISK ASSESSOR: ZOLIAN SMITH
ORGANIZATION: EQUIFAX INC.
ASSESSMENT PERIOD: OCTOBER 1, 2017 - OCTOBER 30, 2017
REPORT DATE: OCTOBER 31, 2017

Zolian R. Smith
August 17, 2025

Risk Assessment Context

This Prevention and Response Plan has been developed as a direct continuation of the comprehensive Risk Assessment Report completed on October 31, 2017, following Equifax's major cybersecurity breach that occurred between May and July 2017. The Risk Assessment identified five critical assets with varying risk scores: Corporate Reputation (21.7 - highest risk), Customer Personal Data Repository (20.3), Consumer Credit Database (19.0), Web Application Infrastructure (15.0), and IT Network Systems (13.7). This Prevention and Response Plan directly addresses the threats, vulnerabilities, and risks identified in that assessment, providing specific actionable tasks to reduce the likelihood of future security incidents and establish comprehensive response procedures to minimize damage if breaches occur. The plan is specifically designed to protect Equifax's most critical assets while restoring stakeholder confidence and ensuring regulatory compliance in the aftermath of the 2017 data breach incident.

Internal and External Context

This Prevention and Response Plan was developed in response to the catastrophic 2017 data breach that compromised 147.9 million American consumers' personal information, resulting in a $1.38 billion settlement and severe reputational damage. The plan addresses the urgent need to restore stakeholder confidence, meet heightened regulatory scrutiny, and prevent future incidents of similar magnitude. Internally, the organization requires comprehensive security transformation to protect critical data assets and maintain business operations. Externally, Equifax faces ongoing legal challenges, regulatory oversight, and the need to rebuild consumer trust in its credit reporting services. The potential benefits from implementing this plan include: restored customer confidence, reduced regulatory penalties, improved security posture against Advanced Persistent Threats and Web Application Attacks, protection of the $15+ billion annual revenue stream, and positioning Equifax as an industry leader in data protection. The plan provides a structured approach to risk mitigation that directly addresses the specific threats identified in the Risk Assessment, ensuring that resources are allocated effectively to protect the organization's most valuable and vulnerable assets.

Scope

This Prevention and Response Plan addresses the risks to Equifax Inc.'s information systems and data assets following the 2017 cybersecurity incident, specifically targeting the five critical assets identified in the Risk Assessment Report. The plan covers all information systems containing consumer credit data, personally identifiable information (PII), financial records, and business-critical applications within Equifax's U.S. operations, with particular focus on the Apache Struts-based Web Application Infrastructure that was the original attack vector. It encompasses prevention strategies for Advanced Persistent Threats, SQL Injection Attacks, Data Exfiltration, Network Intrusions, and Unauthorized Access scenarios, while establishing response procedures for incident detection, analysis, recovery, and post-incident review. The plan does not cover risks related to Equifax's international subsidiaries' independent systems, third-party vendor systems not directly integrated with Equifax infrastructure, or physical security risks unrelated to the cyber incident. Additionally, financial risks related to stock price fluctuations and market competition outside of cybersecurity implications are excluded from this plan's scope, as these fall under separate business risk management frameworks.

Prevention Plan

Security Measures

- **First Task:** Implement Advanced Vulnerability Management Program
  This task directly addresses the Apache Struts vulnerability (CVE-2017-5638) that caused the original breach by establishing automated vulnerability scanning across all Web Application Infrastructure systems, prioritized patching schedules based on the Risk Assessment findings, and continuous monitoring of security advisories. The implementation will significantly reduce the likelihood of exploitation by ensuring all systems are up-to-date with the latest security patches, particularly targeting the Web Application Infrastructure which scored 15.0 in the risk assessment and faces threats from Unpatched Vulnerabilities and Web Application Attacks.

- **Second Task:** Deploy Zero-Trust Network Architecture
  Following the Risk Assessment findings that identified Network Intrusions, Lateral Movement, and System Compromises as significant threats to IT Network Systems (Risk Score: 13.7), this task implements a zero-trust model ensuring no user or device is trusted by default. The architecture includes micro-segmentation to isolate the Customer Personal Data Repository (Risk Score: 20.3), continuous authentication verification, and strict access controls based on the principle of least privilege, significantly reducing the attack surface and preventing unauthorized access to critical assets.

- **Third Task:** Establish Comprehensive Data Encryption and Tokenization
  This security measure directly protects the Customer Personal Data Repository, identified as the second-highest risk asset (Risk Score: 20.3) facing threats of Data Exfiltration, Ransomware Attacks, and Unauthorized Access. Implementation includes end-to-end encryption for all stored PII, tokenization of sensitive data elements like Social Security numbers, and deployment of Hardware Security Modules (HSMs) for cryptographic key management, rendering stolen data unusable even if accessed by attackers.

Employee Training

- **First Task:** Implement Security Awareness Training Program
  Given that Insider Threats were identified as a risk to the Consumer Credit Database (Risk Score: 19.0), this comprehensive training program educates all employees on recognizing social engineering attacks, proper handling of sensitive consumer credit data, incident reporting procedures, and security best practices. Regular training sessions, simulated phishing exercises targeting Equifax-specific scenarios, and monthly security updates ensure employees understand their critical role in protecting customer data and reducing human error vulnerabilities.

- **Second Task:** Establish Role-Based Security Training
  This task provides specialized security training based on employee roles and their access to the five critical assets identified in the Risk Assessment. Technical staff receive advanced training on secure coding practices to prevent SQL Injection Attacks, system administration security for IT Network Systems, and threat detection for Advanced Persistent Threats, while management focuses on security governance,

risk management decision-making, and incident response leadership to protect Corporate Reputation (highest risk asset at 21.7).

- **Third Task:** Create Incident Response Training and Simulation Exercises
  Regular incident response exercises prepare employees to respond effectively to security incidents, directly addressing the need for rapid response to protect Corporate Reputation (Risk Score: 21.7) from Media Coverage, Regulatory Actions, and Customer Defection. These simulations test communication procedures, escalation protocols, and recovery processes while identifying improvement areas, covering specific scenarios relevant to Equifax's risk profile including data breach response, regulatory notification requirements, and crisis communication strategies.

Response Plan

Preparation

1. **First task:** Establish 24/7 Security Operations Center (SOC)
    - **Responsibility:** Chief Security Officer
    - **Description of task:** Deploy continuous monitoring capabilities for all critical assets identified in the Risk Assessment, with particular focus on the Customer Personal Data Repository and Consumer Credit Database. The SOC will provide real-time threat detection, automated alerting for Advanced Persistent Threats, SQL Injection Attacks, and Data Exfiltration attempts, ensuring rapid identification of security incidents before they impact critical business operations or customer data.
2. **Second task:** Develop Comprehensive Incident Response Playbooks
    - **Responsibility:** Chief Technology Officer
    - **Description of task:** Create detailed response procedures for each type of threat identified in the Risk Assessment, including specific playbooks for Web Application Attacks targeting the Apache Struts infrastructure, Network Intrusions affecting IT systems, and Unauthorized Access to customer data repositories. These playbooks outline step-by-step response procedures, communication protocols, legal notification requirements, and escalation criteria for consistent incident response.

Detection and Analysis

3. **First task:** Deploy AI-Powered Behavioral Analytics System
    - **Responsibility:** IT Security Manager
    - **Description of task:** Implement machine learning-based monitoring system to analyze access patterns to the Customer Personal Data Repository and Consumer Credit Database, automatically detecting anomalies that could indicate Data Exfiltration or Insider Threats. The system analyzes user behavior, data access patterns, and system interactions to identify potential security incidents, providing early warning capabilities for the high-risk scenarios identified in the Risk Assessment.
4. **Second task:** Implement Automated Threat Intelligence Integration
    - **Responsibility:** Security Operations Manager
    - **Description of task:** Integrate real-time threat intelligence feeds to enable rapid identification of new attack vectors and tactics, particularly those targeting Web Application Infrastructure vulnerabilities similar to the original Apache Struts exploit (CVE-2017-5638). This capability enhances threat detection by correlating internal security events with global threat intelligence, supporting proactive protection of Corporate Reputation through early threat identification.

Recovery

5. **First task:** Execute Data Recovery and System Restoration Procedures
    - **Responsibility:** Chief Technology Officer
    - **Description of task:** Implement comprehensive recovery procedures to restore affected systems while maintaining data integrity for the Consumer

Credit Database and Customer Personal Data Repository. This includes activation of backup systems, data validation processes to ensure no corruption occurred, systematic restoration of services in order of business criticality, and coordination with regulatory bodies regarding system availability and data protection measures.

6. **Second task:** Activate Crisis Communication Plan
    - **Responsibility:** Chief Executive Officer
    - **Description of task:** Execute immediate and transparent communication with stakeholders to protect Corporate Reputation (highest risk asset at 21.7) from further damage due to Media Coverage and Customer Defection. The plan includes pre-approved messaging for different incident types, media response protocols, customer notification procedures meeting legal requirements, regulatory reporting within mandated timeframes, and investor communication to maintain market confidence.

Follow-up and Post-Incident Review

7. **First task:** Conduct Comprehensive Incident Analysis
    - **Responsibility:** Lead Risk Assessor
    - **Description of task:** Perform thorough analysis of the incident to identify root causes, assess the effectiveness of response measures, and evaluate the impact on each of the five critical assets identified in the Risk Assessment. This includes timeline reconstruction, system log analysis, forensic investigation of affected systems, impact assessment on the Consumer Credit Database and Customer Personal Data Repository, and evaluation of how well the response protected Corporate Reputation from additional damage.
8. **Second task:** Update Risk Assessment and Treatment Plans
    - **Responsibility:** Chief Security Officer
    - **Description of task:** Revise the Risk Assessment to reflect new threats discovered during the incident, changed vulnerabilities in the Web Application Infrastructure and IT Network Systems, and updated risk scores for all assets based on incident findings. This ensures the organization's risk profile remains current and mitigation strategies are adjusted accordingly, informing future prevention planning and resource allocation for protecting critical assets.

Improvements

9. **First task:** Implement Enhanced Security Architecture
    - **Responsibility:** Chief Technology Officer
    - **Description of task:** Deploy security architecture improvements based on incident lessons learned, addressing identified weaknesses in the Web Application Infrastructure and IT Network Systems. This includes additional network segmentation to isolate the Customer Personal Data Repository, enhanced access controls with multi-factor authentication, improved monitoring capabilities for Advanced Persistent Threats, and deployment of new security technologies specifically designed to protect high-risk assets identified in the Risk Assessment.
10. **Second task:** Strengthen Regulatory Compliance and Reporting Capabilities
    - **Responsibility:** Chief Compliance Officer

- **Description of task:** Develop enhanced compliance capabilities to address regulatory implications highlighted in the Risk Assessment, particularly regarding Corporate Reputation and Customer Personal Data Repository protection. This includes implementation of improved incident reporting systems for regulatory bodies, enhanced audit capabilities for ongoing compliance verification, stronger governance frameworks for data protection oversight, and establishment of regular compliance assessments to prevent future regulatory violations.